LAPORAN AUDIT KODE SUMBER

FASE 1 — READ-ONLY CODEBASE INSPECTION & ARCHITECTURE AUDIT

Aplikasi: **Mini ERP Keylock Indonesia** (Rental, Sales, Logistics & CMS)

PT KEYLOCK INDONESIA

TARGET STACK	TARGET DEPLOYMENT	AUDITOR ROLE	STATUS AUDIT
Laravel 12 & PostgreSQL	Shared Hosting / cPanel	Sr. Architect & Sec Auditor	Fase 1 Selesai (Read-Only)

10	2	3	3	2
TOTAL TEMUAN	CRITICAL (RCE/PRIV)	HIGH (IDOR/DB/SEC)	MEDIUM (POSTGRE/RACE)	LOW / QUALITY

1 RINGKASAN KONDISI PROYEK

Aplikasi **Mini ERP Keylock Indonesia** saat ini berada pada tahap kematangan fungsional sekitar **90%**. Sistem ini mengintegrasikan seluruh alur operasional bisnis alat berat dan logistik: penawaran harga (*quotation*), transaksi rental dan penjualan (*sales/rental orders*), surat jalan pengiriman (*Delivery Order / DO*), pengadaan unit & vendor (*procurement PO & vendor bills*), alokasi armada/alat berat (*fleet management*), keuangan (*invoices & kas/payments*), CRM pipeline leads, serta manajemen konten website publik (CMS).

Secara arsitektur, aplikasi dirancang menggunakan pola **Monolith Hybrid** yang menggabungkan:

- **Controller Kustom Berbasis Laravel Blade + Tailwind CSS + Alpine.js**: Melayani modul operasional utama harian staf ERP.
- **Filament Admin Panel v3**: Dipasang berdampingan pada namespace URL `/erp` untuk administrasi data pelengkap.
- **RESTful API Endpoints Bertingkat Throttle**: Melayani integrasi katalog publik dan calon aplikasi mobile.

Catatan Kritis Hasil Audit: Ditemukan beberapa kelemahan arsitektural dan celah keamanan berisiko tinggi:

- Potensi **Arbitrary File Upload / Remote Code Execution (RCE)** melalui manipulasi string base64 pada unggahan gambar quotation.
- Bypass hak akses menyeluruh (**Privilege Escalation**) akibat ketiadaan middleware otorisasi pada endpoint manajemen user, role, dan menu.
- Inkompatibilitas query SQL non-portabel (`MONTH()` dan case-sensitive `LIKE`) yang memicu fatal error saat migrasi ke database PostgreSQL.
- Eksposur arsip sumber kode lengkap (`keylock.zip`) di root direktori berpotensi bocor di web server shared hosting.

2 INVENTARISASI KOMPONEN YANG DITEMUKAN

KOMPONEN	SPESIFIKASI & TEMUAN	STATUS
Versi PHP	`^8.2` (terverifikasi dari `composer.json` baris 9)	TERVERIFIKASI
Versi Framework	**Laravel Framework 12.0** (`^12.0`, `composer.json` baris 11)	TERVERIFIKASI
Dependency Utama	`filament/filament: ^3.2`, `laravel/sanctum: ^4.0`, `laravel/tinker: ^2.10.1`	TERVERIFIKASI
Paket PDF Engine	**Tidak ada paket PDF pihak ketiga** (seperti `barryvdh/laravel-dompdf` atau `mpdf`). Cetak PDF menggunakan HTML Blade printable view (`window.print()`).	NATIVE VIEW
Konfigurasi Database	Default driver: `env('DB_CONNECTION', 'sqlite')` dengan blok koneksi `pgsql` terdefinisi (`config/database.php`).	TERVERIFIKASI

KOMPONEN	SPESIFIKASI & TEMUAN	STATUS
Routes Web	**111 rute web** terdaftar di `routes/web.php` (modul ERP, auth session, cetak printable, redirect).	TERVERIFIKASI
Routes API	Terdaftar di `routes/api.php` dengan proteksi throttle publik (`60,1`) dan endpoint `/api/user` Sanctum.	TERVERIFIKASI
Controllers	- **Erp Namespace (7 controller)**: `ErpController.php` (2.142 baris), `CrmController.php`, `ProcurementController.php`, `CmsController.php`, `FinanceController.php`, `FleetController.php`, `ConfigController.php`. - **Api Namespace**: 7 controller | **Auth**: `AuthenticatedSessionController.php`	TERVERIFIKASI
Middleware Kustom	Hanya 1 berkas: `app/Http/Middleware/CheckRole.php` (alias `'role'` di `bootstrap/app.php`).	TERBATAS
Form Requests	**Tidak ditemukan direktori `app/Http/Requests`**. Validasi input dijalankan inline dalam controller.	ABSEN
Policies & Gates	**Tidak ditemukan direktori `app/Policies`**. Tidak ada Gate kustom yang didaftarkan.	ABSEN
Services / Action Classes	**Tidak ditemukan direktori `app/Services` atau `app/Actions`**. Seluruh business logic berada di Controller.	ABSEN
Jobs, Events, Listeners	**Tidak ditemukan direktori `app/Jobs`, `app/Events`, atau `app/Listeners`**.	ABSEN
Model Eloquent	**29 Model** di `app/Models/` (Order, OrderItem, Contact, Item, Asset, Delivery, Invoice, Payment, Lead, dll.).	TERVERIFIKASI
Database Migrations	**42 berkas migration** di `database/migrations/`.	TERVERIFIKASI
Database Seeders	7 seeder: `DatabaseSeeder`, `MiniErpSeeder`, `AppMenuSeeder`, `CrmLeadSeeder`, dll.	TERVERIFIKASI
Automated Tests	Hanya berkas bawaan Laravel (`ExampleTest.php`). **Coverage pengujian bisnis = 0%**.	0% COVERAGE

3 DAFTAR MODUL BISNIS YANG DIIDENTIFIKASI

1. Otentikasi & Akun
Otentikasi sesi berbasis email/password, session cookie, proteksi CSRF, dan manajemen logout.

2. Dashboard Operasional
Ringkasan KPI performa penjualan bulanan, target penjualan, utilisasi unit, dan pipeline CRM.

3. Sales & Penawaran (Quotation)
Pembuatan penawaran multi-item (rental/jual), kalkulasi PPN 11%, PPh 23 2%, diskon, ongkir PP, dan cetak PDF.

4. Transaksi & Order
Konversi quotation menjadi rental/sales order aktif, pelacakan status (draft, approved, in_progress, completed, cancelled).

5. Logistik & Pengiriman (DO)
Penerbitan Surat Jalan / Delivery Order, tanggal kirim, nomor polisi armada, driver, ekspedisi, dan tanda terima PIC.

6. Pengadaan & Vendor (PO)
Pembuatan Purchase Order vendor, alokasi unit vendor ke pesanan pelanggan, kalkulasi margin kotor, dan tagihan vendor.

7. Keuangan & Penagihan (Finance)
Penagihan pelanggan (AR Invoices), utang vendor (AP Bills), riwayat kas riil masuk/keluar, dan verifikasi bukti bayar.

8. Armada & Unit (Fleet Management)
Registrasi unit (milik sendiri vs vendor), nomor seri/plat/kode aset, alokasi pesanan, dan histori servis berkala.

9. CRM & Pipeline Leads
Kanban board leads multi-tahap, aktivitas call/meeting/demo, log follow-up, dan konversi leads menjadi pelanggan resmi.

10. Konfigurasi Sistem (Master Config)
Manajemen dropdown dinamis, profil perusahaan, nomor rekening bank pembayaran, NPWP, dan parameter aplikasi.

11. Hak Akses & Menu Dinamis
Konfigurasi pohon menu sidebar dinamis dan hak akses per user group (tabel `appmenus` dan `appmenuaccess`).

12. CMS Website Publik
Manajemen konten website: katalog produk, kategori, galeri proyek, logo mitra, testimoni, profil 'tentang kami', dan kontak WeChat.

4 DAFTAR BERKAS YANG DIPERIKSA

- **Konfigurasi & Bootstrap**: `composer.json`, `bootstrap/app.php`, `config/database.php`, `config/filesystems.php`, `config/services.php`.
- **Rute Aplikasi**: `routes/web.php` (111 routes), `routes/api.php`.
- **Middleware**: `app/Http/Middleware/CheckRole.php`.
- **Controller ERP Utama**: `ErpController.php`, `ProcurementController.php`, `FinanceController.php`, `CrmController.php`, `FleetController.php`, `CmsController.php`, `ConfigController.php`, `AuthenticatedSessionController.php`.
- **Providers**: `AppServiceProvider.php`, `AdminPanelProvider.php` (Filament).
- **Model Inti**: `User.php`, `Order.php`, `OrderItem.php`, `Invoice.php`, `Payment.php`, `Delivery.php`, `Asset.php`, `Lead.php`, `Contact.php`, `AppMenu.php`, `AppMenuAccess.php`.
- **Database & Server**: `database/migrations/` (42 files), `database/seeders/` (7 files), `public/.htaccess`, serta file arsip `keylock.zip`.

5 DAFTAR AREA YANG BELUM DAPAT DIPERIKSA (BATASAN FASE 1)

1. **Konfigurasi Server cPanel Target Sesungguhnya**: Belum dapat memeriksa konfigurasi nyata PHP cPanel (ekstensi `pdo_pgsql`, `memory_limit`, `upload_max_filesize`, dan `max_execution_time`).
2. **Ketersediaan Symlink Web Server**: Belum memverifikasi apakah shared hosting mengizinkan symlink (`public_html/storage -> storage/app/public`) atau menonaktifkan fungsi `symlink()`.
3. **Versi & Hak Akses PostgreSQL Remote**: Belum memverifikasi limit koneksi bersama, schema non-public, dan koneksi SSL hosting PostgreSQL.
4. **Isi Berkas .env Production**: Sesuai aturan read-only dan standar audit, berkas `.env` tidak dibuka maupun ditampilkan demi menjaga kerahasiaan kredensial.
5. **Worker Daemon & Scheduler**: Belum dapat memverifikasi ketersediaan Supervisor/daemon pada cPanel untuk background worker queue.

6 TEMUAN AWAL DENGAN BUKTI KODE & ANALISIS DAMPAK

TEMUAN 1: Unrestricted File Upload via Base64 Berpotensi RCE (Remote Code Execution)

CRITICAL CONFIRMED

Berkas: app/Http/Controllers/Erp/ErpController.php (L1147-1164 di storeQuotation, L1330-1346 di updateQuotation)

```
if (!empty($imagePath) && str_starts_with($imagePath, 'data:image/')) {
    @list($type, $data) = explode(';', $imagePath);
    @list(, $data) = explode(',', $data);
    if ($data) {
        $decoded = base64_decode($data);
        $ext = 'png';
        if (preg_match('/image\/([a-zA-Z0-9]+)/', $type, $m)) {
            $ext = $m[1]; // Ekstensi diambil mentah dari MIME input pengguna
        }
        $filename = 'quotation_items/' . uniqid('unit_') . '.' . $ext;
        \Illuminate\Support\Facades\Storage::disk('public')->put($filename, $decoded);
        $imagePath = 'storage/' . $filename;
    }
}
```

Analisis Dampak: Ekstensi berkas diekstrak langsung dari header MIME `data:image/<ext>` tanpa whitelist ekstensi aman (seperti `png`, `jpg`, `webp`). Penyerang dapat mengirim payload base64 dengan header `...` sehingga sistem akan menyimpan berkas `unit_xxx.php` langsung ke dalam folder publik `storage/app/public/quotation_items/`. Pada web server Apache/LiteSpeed di cPanel, berkas ini dapat dieksekusi via browser, menghasilkan pengambilalihan server penuh (**Remote Code Execution**).

TEMUAN 2: Ketiadaan Middleware Otorisasi & Role Check pada Endpoint Administratif

CRITICAL CONFIRMED

Berkas: routes/web.php (L36-163) & app/Http/Controllers/Erp/ErpController.php (L548-647)

```
// routes/web.php L36:
Route::middleware(['auth'])->group(function () {
    Route::prefix('erp')->name('erp.')->group(function () {
        Route::get('/users', [ErpController::class, 'userManagement'])->name('users.index');
        Route::post('/users', [ErpController::class, 'storeUser'])->name('users.store');
        Route::post('/users/{id}/update', [ErpController::class, 'updateUser'])->name('users.update');
        Route::post('/roles', [ErpController::class, 'storeRole'])->name('roles.store');
        Route::post('/roles/{id}/delete', [ErpController::class, 'deleteRole'])->name('roles.delete');
        Route::get('/system-menus', [ErpController::class, 'systemMenus'])->name('menus.index');
        Route::post('/system-menus/access/sync', [ErpController::class, 'syncMenuAccess'])-
>name('menus.access.sync');
    });
});
```

Analisis Dampak: Middleware `CheckRole` (alias `'role'`) sudah terdaftar di `bootstrap/app.php`, namun **sama sekali tidak pernah dipasang** pada rute `/erp/*`. Controller juga tidak menerapkan Gate/Policy. Akibatnya, setiap pengguna yang berhasil login (meskipun role-nya hanya *Staff* atau *Sales*) dapat mengirim request POST ke `/erp/users` untuk membuat akun admin baru atau mengubah password akun Superadmin (**Privilege Escalation**).

TEMUAN 3: Akses Terbuka Tanpa Batas ke Filament Admin Panel

HIGH CONFIRMED

Berkas: app/Models/User.php (L107-110)

```
public function canAccessPanel(Panel $panel): bool
{
    return true; // Mengizinkan semua user login ke Filament tanpa validasi peran admin!
}
```

Analisis Dampak: Method `canAccessPanel()` mengembalikan nilai `true` untuk seluruh akun terotentikasi tanpa verifikasi hak admin (`isAdmin()`). Setiap pengguna non-admin dapat mengakses antarmuka Filament pada namespace `/erp` untuk mengedit atau menghapus katalog master dan konfigurasi.

TEMUAN 4: Kerentanan IDOR (Insecure Direct Object References) pada Mutasi & Dokumen

HIGH CONFIRMED

Berkas: ErpController.php (L1752-1776, L1856-1873) & ProcurementController.php (L93-95)

```
public function cancelOrder(Request $request, $id)
{
    $order = Order::findOrFail($id); // Tanpa validasi kepemilikan/otoritas pembatalan!
    ...
    $order->update(['status' => 'cancelled', 'cancel_reason' => $validated['cancel_reason']]);
}
```

Analisis Dampak: Pengguna biasa dapat membatalkan pesanan milik sales lain atau mengunduh PDF penawaran internal perusahaan lain hanya dengan mengganti parameter ID numerik pada URL (`/quotations/1/pdf`, `/quotations/2/pdf`, dll.).

TEMUAN 5: Penggunaan Fungsi SQL MySQL MONTH() yang Inkompatibel dengan PostgreSQL

HIGH CONFIRMED

Berkas: app/Http/Controllers/Erp/ErpController.php (L86-90)

```
$rawMonthly = Order::selectRaw('MONTH(order_date) as m, order_type, quotation_type, sum(total_amount) as total')
    ->whereIn('status', ['approved', 'in_progress', 'completed'])
    ->whereYear('order_date', now()->year)
    ->groupBy('m', 'order_type', 'quotation_type')
    ->get();
```

Analisis Dampak: Fungsi `MONTH()` adalah fungsi bawaan MySQL. Di PostgreSQL, fungsi ini **tidak ada** (PostgreSQL menggunakan `EXTRACT(MONTH FROM order_date)`). Ketika database beralih ke PostgreSQL, halaman utama dashboard ERP (`/erp`) akan langsung crash dengan fatal error: `SQLSTATE[42883]: Undefined function: 7 ERROR: function month(date) does not exist`.

TEMUAN 6: Pencarian Case-Sensitive pada Operator LIKE di PostgreSQL

MEDIUM CONFIRMED

Berkas: ProcurementController.php (L54-67), FleetController.php (L48-61), FinanceController.php (L112-161), ErpController.php (L474-491)

```
$q->where('order_number', 'like', "%{$search}%")
  ->orWhereHas('contact', function ($cq) use ($search) {
      $cq->where('name', 'like', "%{$search}%");
  });
```

Analisis Dampak: Di MySQL, operator `LIKE` bersifat case-insensitive secara default. Di PostgreSQL, `LIKE` bersifat **strict case-sensitive**. Jika staf mencari "astra", sistem tidak akan menemukan pelanggan bernama "PT ASTRA", sehingga fitur pencarian tampak rusak. Diperlukan operator `ILIKE` atau fungsi `LOWER()`.

TEMUAN 7: Potensi Race Condition pada Penomoran Otomatis Dokumen Bisnis

MEDIUM CONFIRMED

Berkas: ErpController.php (L1073-1074) & FinanceController.php (L394-395)

```
$nextId = (Order::where('order_type', 'quotation')->count() + 1);
$orderNumber = 'QTN-' . date('Ym') . '-' . str_pad($nextId, 3, '0', STR_PAD_LEFT);
```

Analisis Dampak: Menggunakan `count() + 1` tanpa *database lock* berisiko menghasilkan nomor dokumen kembar saat 2 user menyimpan penawaran bersamaan, atau crash karena pelanggaran indeks `unique` jika ada record lama yang dihapus.

TEMUAN 8: Beban Query Berulang Tanpa Cache pada View Composer

MEDIUM CONFIRMED

`Berkas: app/Providers/AppServiceProvider.php (L33-41)`

```
View::composer(['layouts.erp', 'erp.*'], function ($view) {
    $userGrpId = auth()->check() ? (auth()->user()->usergrpid ?? 1) : 1;
    $sidebarMenus = AppMenu::getTreeForUser($userGrpId, 'erp');
    $customers = Contact::where('type', 'customer')->where('is_active', true)->orderBy('name')->get();
    $catalogItems = Item::where('is_active', true)->get();
    $activeQuotationsCount = Order::where('order_type', 'quotation')->count();
    $view->with(compact('sidebarMenus', 'customers', 'catalogItems', 'activeQuotationsCount'));
});
```

Analisis Dampak: Setiap kali tampilan Blade `erp.*` dirender (termasuk AJAX modals), sistem mengeksekusi 4 query database berat yang menarik seluruh data pelanggan dan katalog produk. Di shared hosting dengan latensi database eksternal, ini memperlambat response time secara signifikan.

TEMUAN 9: Keberadaan Arsip Sumber Kode Sensitif di Root Direktori Proyek

HIGH CONFIRMED

`Berkas: keylock.zip (Ukuran: 38,5 MB di direktori utama repositori)`

Analisis Dampak: File zip cadangan `keylock.zip` berada di root direktori. Pada shared hosting di mana web server sering kali keliru diarahkan ke root folder aplikasi (bukan ke `/public`), berkas ini dapat diunduh publik via URL (`https://domain.com/keylock.zip`), mengakibatkan kebocoran seluruh source code, database scheme, dan konfigurasi.

TEMUAN 10: Monolithic "God" Controller

QUALITY / LOW CONFIRMED

`Berkas: app/Http/Controllers/Erp/ErpController.php (Ukuran: 91,9 KB, 2.142 baris kode)`

Analisis Dampak: `ErpController` mengelola terlalu banyak domain bisnis sekaligus (dashboard kpi, kontak, user & role, menu dinamis, penawaran harga, transaksi rental/sales, delivery order, invoicing, dan PDF generation). Ini menyulitkan pemeliharaan, pengujian unit, serta meningkatkan risiko regresi saat penambahan fitur.

7 RISIKO KHUSUS POSTGRESQL & SHARED HOSTING / CPANEL

A. Risiko Khusus PostgreSQL:

1. **Case-Sensitivity**: Seluruh klausa `LIKE` bersifat case-sensitive. Harus diganti dengan `ILIKE` atau `LOWER()`.
2. **Fungsi Tanggal Non-Portabel**: `MONTH()` akan crash. Wajib diganti dengan `EXTRACT(MONTH FROM col)`.
3. **Penanganan Sequence (Auto-Increment)**: Insert manual dengan ID eksplisit dapat merusak urutan `table_id_seq` dan memicu error *duplicate key*.
4. **Batas Koneksi Bersama**: Host PostgreSQL sering membatasi 15-30 concurrent connection. Ketiadaan PgBouncer dapat menyebabkan fatal error koneksi penuh.

B. Risiko Khusus Shared Hosting / cPanel:

1. **Document Root /public**: Jika document root tidak diarahkan tepat ke `public_html/public`, berkas `.env` dan `keylock.zip` terekspos ke publik.
2. **Ketiadaan Symlink Engine**: Jika fungsi `symlink()` dinonaktifkan hoster, `php artisan storage:link` gagal dan gambar unit/bukti bayar tidak tampil.
3. **Batas Worker Daemon**: cPanel jarang menyediakan daemon Supervisor untuk queue. Proses asinkron harus digantikan cPanel Cron (`schedule:run`).
4. **Batas Eksekusi PHP (Max Execution Time)**: `set_time_limit(180)` di `AppServiceProvider` sering diabaikan oleh PHP-FPM hoster (timeout 30-60 detik).

8 REKOMENDASI URUTAN REMEDIASI (ACTION PLAN)

FASE PRIORITAS	TINDAKAN REMEDIASI TEKNIS	TARGET BERKAS

PRIORITAS 1
Keamanan Kritis & Akses
	1. Validasi ketat MIME & whitelist ekstensi gambar base64 (hanya izinkan `jpg, jpeg, png, webp`).
	2. Pasang middleware `role:admin` pada route grup user, role, dan menu.
	3. Batasi `canAccessPanel()` di model User agar hanya akun admin yang dapat login ke Filament.
	4. Hapus atau amankan berkas arsip `keylock.zip` dari direktori root.
		`ErpController.php`
		`routes/web.php`
		`app/Models/User.php`
		Root folder

PRIORITAS 2
Kompatibilitas PostgreSQL
	1. Ganti `MONTH(order_date)` dengan `EXTRACT(MONTH FROM order_date)` atau koleksi Carbon.
	2. Ubah operator pencarian string dari `like` menjadi `ilike` atau `whereRaw('LOWER(col) LIKE ?')` agar pencarian bersifat case-insensitive.
		`ErpController.php`
		`ProcurementController.php`
		`FinanceController.php`
		`FleetController.php`

PRIORITAS 3
Integritas Data & IDOR
	1. Terapkan `lockForUpdate()` (pessimistic locking) atau generator sequence pada penomoran dokumen `QTN-`, `INV-`, `DO-`, dan `PO-`.
	2. Tambahkan verifikasi otorisasi/kepemilikan order sebelum mengeksekusi pembatalan atau render PDF transaksi.
		`ErpController.php`
		`FinanceController.php`
		`ProcurementController.php`

PRIORITAS 4
Optimasi & Arsitektur
	1. Pasang query caching (Cache::remember) pada View Composer di AppServiceProvider.
	2. Siapkan konfigurasi struktur folder cPanel yang aman (core di luar `public_html`).
	3. Refactor method besar di `ErpController` ke Form Requests dan Service Classes.
		`AppServiceProvider.php`
		`app/Http/Requests/*`
		`app/Services/*`

KONFIRMASI INTEGRITAS STRICT READ-ONLY (FASE 1)

Saya mengonfirmasi bahwa selama proses audit kode sumber Fase 1 ini:
✓ Tidak ada berkas yang dibuat, diedit, dipindahkan, atau dihapus di dalam repositori codebase.
✓ Tidak ada perintah database migration, seeder, write, rollback, atau modifikasi data yang dijalankan.
✓ Tidak ada dependency Composer maupun npm yang diperbarui atau dimodifikasi.
✓ Tidak ada kredensial, token, atau variabel rahasia dari `.env` yang dibaca atau ditampilkan.
Laporan ini disusun murni berdasarkan pembacaan statis struktur kode sumber yang ada.

Disiapkan oleh:

Senior Laravel Software Architect & Application Security Auditor

Tanggal Audit:
19 Oktober 2026
Keylock ERP Internal Audit System